

S11L5 - Bonus 1

Esplorazione di Nmap

Parte 1: Esplorazione di Nmap

Cos'è Nmap?

Nmap ("Network Mapper") è uno strumento open source per l'esplorazione della rete e l'audit di sicurezza (network exploration tool and security/port scanner).

Per cosa viene usato Nmap?

Nmap è progettato per scansionare rapidamente reti di grandi dimensioni, anche se funziona bene anche su singoli host. Usa pacchetti IP "raw" per determinare: quali host sono disponibili sulla rete, quali servizi (nome applicazione e versione) questi host offrono, quali sistemi operativi (e versioni) stanno eseguendo, che tipo di filtri di pacchetti/firewall sono in uso, e molte altre caratteristiche. Viene usato sia per audit di sicurezza sia per attività di routine come l'inventario di rete, la gestione degli aggiornamenti dei servizi e il monitoraggio dell'uptime di host/servizi.

Qual è il comando nmap usato nell'Esempio 1 della pagina man?

```
nmap -A -T4 scanme.nmap.org
```

Cosa fa l'opzione -A?

Abilita opzioni di scansione aggressive/avanzate: rilevamento del sistema operativo (-O), rilevamento delle versioni (-sV), scansione con script (-sC) e traceroute (--traceroute). Serve ad attivare un insieme completo di opzioni senza dover ricordare tutti i singoli flag. Attenzione: non va usata contro reti bersaglio senza autorizzazione, perché lo script scanning con il set predefinito è considerato intrusivo. L'opzione -A abilita solo funzionalità, non opzioni di timing (come -T4) o di verbosità (come -v). Le opzioni che richiedono privilegi (es. accesso root), come il rilevamento del sistema operativo e il traceroute, saranno attive solo se quei privilegi sono disponibili.

Cosa fa l'opzione -T4?

Imposta un "timing template" (modello di temporizzazione) che regola la velocità della scansione. Le opzioni vanno da -T0 (paranoid, il più lento) a -T5 (insane, il più veloce): 0=paranoid, 1=sneaky, 2=polite, 3=normal (default), 4=aggressive, 5=insane. L'opzione -T4 velocizza la scansione partendo dal presupposto di avere una rete ragionevolmente veloce e affidabile, imponendo un limite massimo di 10 ms al ritardo dinamico tra le scansioni delle porte TCP. È l'opzione raccomandata dall'autore per chi ha una connessione a banda larga/ethernet decente, offrendo un buon compromesso tra velocità e affidabilità senza il rischio di crash o problemi di banda tipico di -T5.

Parte 2: Scansione delle Porte Aperte

Passo 1: Scansiona il tuo localhost

```
nmap -A -T4 localhost
```

Quali porte e servizi sono aperti?

Sono state rilevate 2 porte aperte su localhost (127.0.0.1); tutte le altre 998 porte TCP risultano closed.

Porta	Servizio	Versione / Dettagli
21/tcp	FTP	vsftpd 3.0.5 — login anonimo consentito (FTP code 230); presente file di test ftp_test
22/tcp	SSH	OpenSSH 10.0 (protocol 2.0)

Passo 2: Scansiona la tua rete

Indirizzo IP e subnet mask della VM (da ip address)

- Indirizzo IP: 10.0.2.15
- Subnet mask: /24 (255.255.255.0)

A quale rete appartiene la tua VM?

10.0.2.0/24

```
nmap -A -T4 10.0.2.0/24
```

Quanti host sono attivi?

È stato rilevato 1 solo host attivo su 256 indirizzi scansionati: la VM stessa (10.0.2.15). Nessun altro dispositivo risultava raggiungibile sulla rete al momento della scansione.

Elenca alcuni dei servizi disponibili sugli host rilevati

Porta	Servizio	Versione / Dettagli
21/tcp	FTP	vsftpd 3.0.5 — login anonimo consentito; file ftp_test presente
22/tcp	SSH	OpenSSH 10.0 (protocol 2.0)

Passo 3: Scansiona un server remoto

Qual è lo scopo del sito scanme.nmap.org?

È un server messo a disposizione volontariamente dal creatore di Nmap (Fyodor/Insecure.org) per permettere a chi impara ad usare Nmap di esercitarsi facendo scansioni su un bersaglio reale e raggiungibile via internet, autorizzato allo scopo, evitando così problemi etici o legali legati alla scansione di sistemi altrui senza permesso.

```
nmap -A -T4 scanme.nmap.org
```

Quali porte e servizi sono aperti?

Porta	Servizio	Versione
22/tcp	SSH	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (protocol 2.0)
80/tcp	HTTP	Apache httpd 2.4.7 (Ubuntu) — titolo pagina "Go ahead and ScanMe!"
9929/tcp	nping-echo	Nping echo

31337/tcp	tcpwrapped	—
-----------	------------	---

Quali porte e servizi sono filtrati?

Non risultano porte filtrate elencate singolarmente: l'output riporta "Not shown: 996 filtered tcp ports (no-response)", cioè 996 porte raggruppate in un unico conteggio perché non hanno risposto alla sonda (probabilmente bloccate da un firewall).

Qual è l'indirizzo IP del server?

45.33.32.156 (indirizzo IPv6 associato, non scansionato: 2600:3c01::f03c:91ff:fe18:bb2f)

Qual è il sistema operativo?

Linux (CPE: cpe:/o:linux:linux_kernel), riconducibile a Ubuntu in base alle versioni di SSH e Apache rilevate.

Domanda di Riflessione

Nmap è uno strumento potente per l'esplorazione e la gestione della rete. Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Uso difensivo (blue team / amministratori di rete)

- Individuare tutti i dispositivi e i servizi attivi, comprese macchine "shadow IT" non autorizzate.
- Scoprire porte aperte non necessarie, servizi obsoleti o mal configurati (es. FTP anonimo, come rilevato in questo laboratorio).
- Verifica delle regole firewall: controllare che le policy di filtraggio blocchino effettivamente le porte previste.
- Identificare versioni software vulnerabili tramite il rilevamento dei banner di servizio.
- Monitoraggio dell'uptime e della disponibilità di host e servizi critici nel tempo.

Uso malevolo (attaccante)

- Ricognizione (reconnaissance): fase iniziale di un attacco per mappare la rete bersaglio, scoprire host attivi e i servizi esposti.
- Fingerprinting: identificare sistema operativo e versioni esatte dei servizi per cercare vulnerabilità (CVE) note e sfruttabili.
- Individuazione di punti deboli: porte aperte non necessarie, servizi con configurazioni permissive (es. accesso FTP anonimo) o software non aggiornato diventano potenziali vettori di attacco.
- Preparazione di attacchi mirati: le informazioni raccolte vengono usate per pianificare exploit specifici invece di attacchi generici, aumentando le probabilità di successo.

In sintesi, Nmap è uno strumento neutro: la stessa capacità di scoprire host, porte e servizi che permette a un amministratore di proteggere la propria rete è ciò che un attaccante sfrutta per pianificare un'intrusione.